课程编号：

《开源创新思维》
平时作业报告

姓　　名	陈思宇	学　　号	f25015220
班　　级	f250117	指　导　教　师	祝欣蓉
开　设　学　期	2026-2027 秋 季 学 期		
开　设　时　间	第 1 周 — — 第 16 周		
报　告　日　期	2026 年 10 月 29 日		
评　定　成　绩		评　定　人	祝欣蓉
		评　定　日　期	

上海杉达学院

一、开源项目介绍

1.1 项目概况

本次测试选取 Apache 软件基金会（ASF）顶级项目 **Apache Commons CLI**（Maven 坐标 org.apache.commons:commons-cli，版本 1.12.0-SNAPSHOT，克隆自 github.com/apache/commons-cli 主干）。它是 Java 生态最常用的命令行参数解析库之一，支持 POSIX/GNU 风格选项、选项组等特性，2002 年立项至今持续维护。选择原因：ASF 对许可证合规要求严格（LICENSE、NOTICE、源文件头三要素齐备），项目规模适中、便于人工复核，适合检验工具的检出率与误报率。

1.2 代码规模与依赖

仓库受控文件共 **141 个**（另含 36 个目录），约 2.1 MB：Java 源文件 87 个、XML 19 个、YAML/YML 6 个、Markdown 5 个、图像资源 7 个等。运行时**零第三方依赖**；测试域（test scope）依赖 7 个：JUnit Jupiter 与 junit-pioneer（EPL-2.0）、commons-io 2.22.0 与 commons-text 1.15.0（Apache-2.0）、mockito-core（MIT）。

1.3 许可证要素

项目根目录内置 **LICENSE.txt**（Apache-2.0 全文）与 **NOTICE.txt**（Copyright 2002-2026 The Apache Software Foundation）；经 grep 基线交叉验证，87 个 .java 文件 100% 含 ASF 标准许可证头（“Licensed to the Apache Software Foundation…”短头，不含 Copyright 字样）。

二、测试工具的安装过程及遇到的问题

2.1 工具选型

选用参考列表第 27 项 **ScanCode Toolkit 32.5.0**（Apache-2.0 许可，AboutCode 社区出品）。选型理由：① Python 实现、pip 一键安装；② 内置上千条许可证规则（对齐 SPDX License List 3.27），输出许可证表达式、匹配规则与置信度；③ 支持 JSON/HTML/SPDX 等多种报告；④ 相比 Fossology（需部署服务端）、Apache Rat（需 Java/Maven 环境），更贴合单机测试条件。

2.2 安装步骤

① 使用 uv 安装官方 CPython 3.12.13；② 创建虚拟环境 .venv-scan 隔离依赖；③ 执行 pip install scancode-toolkit==32.5.0，自动安装 100 余个依赖（含 licensedcode 规则库等）；④ 执行 scancode --version 验证，输出“ScanCode version: 32.5.0 / Output Format 4.1.0 / SPDX 3.27”，安装成功。

2.3 遇到的问题与解决

问题 1：Python 版本不兼容。本机默认 Python 3.14 缺少 scancode-toolkit 及其 C 扩展（intbitset、pyahocorasick 等）的预编译 wheel，源码编译需 MSVC 工具链。解决：改用官方 CPython 3.12.13 建立独立环境。

问题 2：插件框架冲突。首次运行报“ValueError: did not find any pre_scan hooks”。排查发现依赖解析出的 pluggy 1.7.0 与 ScanCode 的插件框架 plugincode 不兼容，降级 pluggy==1.5.0 后恢复正常。

问题 3：输出目录校验。--json-pp 输出父目录不存在时工具直接拒绝运行，需预先创建 result 目录。

问题 4：选项联动约束。单独使用 --max-email 0 报“requires the option(s) --email”，部分选项存在依赖联动，最终改为仅使用 -cl（版权+许可证）与 --processes 2、--timeout 120。上述问题均为环境/配置类，官方文档均有说明，安装总耗时约 7 分钟。

三、工具输出的检测报告

3.1 扫描命令与过程

在项目根目录执行：scancode -cl --json-pp result/scancode-result.json --html result/scancode-report.html --processes 2 --timeout 120 commons-cli。工具先加载插件与文件清单，再以 2 进程并行扫描许可证与版权，全程 **175.28 秒**（0.84 files/sec），**0 错误、0 警告**（图 1）。

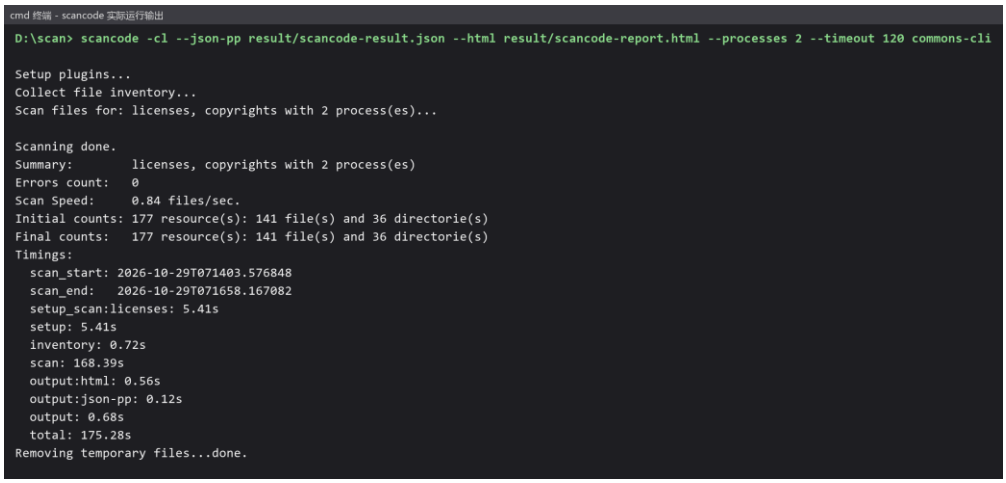


图 1　ScanCode 扫描命令与控制台输出摘要

3.2 总体统计

表 1　扫描总体统计

统计指标	结果
扫描文件总数	141（另含 36 个目录，共 177 个资源）
扫描选项与耗时	-c 版权 + -l 许可证，--processes 2；175.28 s（0.84 files/sec），0 错误 0 警告
许可证检出情况	132 个文件（93.6%）检出；匹配 141 次：apache-2.0×137、generic-cla×3、unknown-license-reference×1；置信度 137 次 100 分、3 次 95 分、1 次 80 分
未检出文件	9 个（6.4%），清单见表 3
版权声明检出	仅 1 条（NOTICE.txt：Copyright 2002-2026 The Apache Software

	Foundation）
工具与规则库	ScanCode Toolkit 32.5.0 / SPDX License List 3.27

3.3 许可证分布

表 2　许可证检出分布

检出许可证表达式（SPDX）	文件数	占比	说明
Apache-2.0	130	92.2%	全部源码、配置与文档
Apache-2.0 AND (LicenseRef-scancode-generic-cla AND Apache-2.0)	2	1.4%	README.md、CONTRIBUTING.md（人工复核为误报，见 4.2）
（未检出）	9	6.4%	二进制资源与无头文本，见表 3

3.4 HTML 报告节选

HTML 报告（scancode-report.html）按文件列出许可证/版权检出明细，节选见图 2，其中 NOTICE.txt 的版权行与 README.md 的异常表达式清晰可见。

Copyrights and Licenses Information

path	start	end	what	value
commons-cli/.asf.yaml	1	14	license	apache-2.0
commons-cli/CODE_OF_CONDUCT.md	2	15	license	apache-2.0
commons-cli/CONTRIBUTING.md	2	15	license	apache-2.0
commons-cli/CONTRIBUTING.md	91	91	license	generic-cla
commons-cli/CONTRIBUTING.md	93	93	license	apache-2.0
commons-cli/CONTRIBUTING.md	110	110	license	generic-cla
commons-cli/CONTRIBUTING.md	115	115	license	apache-2.0
commons-cli/LICENSE.txt	1	201	license	apache-2.0
commons-cli/NOTICE.txt	2	2	copyright	Copyright 2002-2026 The Apache Software Foundation
commons-cli/NOTICE.txt	4	5	license	apache-2.0
commons-cli/pom.xml	3	16	license	apache-2.0
commons-cli/README.md	2	15	license	apache-2.0
commons-cli/README.md	95	95	license	generic-cla
commons-cli/README.md	95	95	license	apache-2.0
commons-cli/README.md	100	100	license	unknown-license-reference
commons-cli/README.md	100	100	license	apache-2.0
commons-cli/SECURITY.md	2	15	license	apache-2.0
commons-cli/.github/dependabot.yml	1	14	license	apache-2.0
commons-cli/.github/GH-ROBOTS.txt	1	14	license	apache-2.0
commons-cli/.github/pull_request_template.md	2	17	license	apache-2.0
commons-cli/.github/workflows/codeql-analysis.yml	1	14	license	apache-2.0

图 2　ScanCode HTML 检测报告节选（前 28 行）

四、检测结果详细分析

4.1 检出一致性核对

87 个 Java 文件全部检出 apache-2.0，主导规则为 apache-2.0_663.RULE（即 ASF 标准短许可证头），得分 100；与 grep 基线（87/87 含 ASF 头）**完全一致**，代码文件检出率 100%。LICENSE.txt（许可证全文，文本占比 100%）、.htaccess、19 个 XML 与 5 个 YML 等也全部正确识别，说明工具对“标准头 + 全文 + 变体”三类形态均有覆盖。

4.2 误报分析

README.md 与 CONTRIBUTING.md 被输出为复合表达式“Apache-2.0 AND (LicenseRef-scancode-generic-cla AND Apache-2.0)”。人工核对原文：两文件仅在正文中**提及**贡献者许可协议（CLA）并附 Apache-2.0 链接，并非同时依 CLA 与 Apache-2.0 双重授权，属于把“提及”识别为“声明”的表达式污染误报（2/132≈1.5%）。置信度分布亦

佐证：141 次匹配中 137 次满分，而 generic-cla 的 3 次匹配出现 95 分与 80 分的低置信结果。处置方式：以文件实际许可证头为准，人工将两文件归一为 Apache-2.0。

4.3 漏检与盲区分析

9 个未检出文件（表 3）分两类：**7 个图像资源**（png/xcf/gif）本无许可证文本，工具无法从像素中提取许可信息，属于原理性盲区，需依赖仓库级 LICENSE 或目录级声明兜底；**2 个文本文件**（RELEASE-NOTES.txt、download_cli.cgi）确实缺少许可证头，构成真实待整改项。另据 4.1 节，版权扫描仅捕获 1 条声明——原因是 ASF 标准头不含“Copyright”关键字，说明**版权检测与许可证检测是两条独立证据链**，“未检出版权”不等于“无主”，需结合 NOTICE 与版本控制历史人工归档。

表 3　未检出许可证的 9 个文件（按类合并）

未检出文件	类型/大小	归类
RELEASE-NOTES.txt	文本 33.7 KB	无许可证头（发布说明）
src/site/resources/download_cli.cgi	脚本 160 B	无许可证头
logo.png×3、options.png、1x1.gif（分布于 src/media、src/site/resources/images、doc-files）	图像 55.1 KB	二进制资源（部分为 ASF 品牌素材）
src/media/commons-logo-component(-100).xcf	图像 173 KB	GIMP 工程文件

4.4 依赖许可证分析

pom.xml 显示运行时零依赖，7 个依赖均为 test scope：EPL-2.0（JUnit Jupiter、junit-pioneer）不进入发布产物、不随项目分发，不触发 copyleft 传染义务；MIT（Mockito）与 Apache-2.0（commons-io、commons-text）本身宽松。结论：依赖许可证对发布合规**无实质风险**，但需防范测试依赖被误升级为 compile 依赖的情形。

4.5 合规义务核查

对照 Apache-2.0 分发义务逐项核查：① 保留 LICENSE 副本——已内置全文，满足；② 修改文件需附显著声明——由下游使用方执行；③ 保留 NOTICE——存在且版权年份 2002-2026 与实际一致，满足；④ 专利授权与诉讼终止条款——需产品级法务审查确认；⑤ 商标限制——Logo 与 ASF 名称不随 Apache-2.0 自动授权（呼应 4.3 节品牌资源风险）。

五、测试风险分析与改进建议

按“可能性×影响”评估的风险矩阵见表 4。

表 4　风险矩阵与对策

风险项	等级	说明	建议对策
品牌资源授权模糊	中	7 个图像无许可证声明，ASF Logo 受商标政策约束，不属 Apache-2.0 自动授权范围	复用前查阅 ASF 品牌政策；产品分发避免附带项目 Logo
版权信息盲区	中	ASF 标准头无 Copyright 字样，130	以 NOTICE.txt 为准，结合

		个源文件版权未被自动捕获	git history 维护版权清单
表达式误报	低	README/CONTRIBUTING 被并入 generic-cla 形成复合表达式	人工复核归一；扫描配置排除说明性文档
个别文本无许可证头	低	RELEASE-NOTES.txt、download_cli.cgi 缺头	补充 SPDX 标识或纳入豁免清单并记录理由
规则库时效	低	规则库 SPDX 3.27，新许可证存在识别滞后	定期升级 ScanCode，对版本变更做增量扫描
依赖许可证漂移	低	测试依赖含 EPL-2.0/MIT，存在被误升级为编译期依赖的可能	CI 设置许可证白名单门禁

改进建议：① 将扫描命令固化到 CI 流水线，对结果 JSON 与基线做 diff，新增许可证必须人工确认；② 发布时随产物生成 SPDX/CycloneDX 格式 SBOM；③ 对豁免文件建立显式清单并注明理由；④ 引入第二工具（如 Apache Rat）交叉验证，降低单一工具漏检风险。

六、测试结论与充分性说明

本次使用 ScanCode Toolkit 32.5.0 对 Apache Commons CLI 全部 141 个受控文件完成扫描：代码文件许可证检出率 100%，仓库主体许可证为 Apache-2.0，与 LICENSE、NOTICE、文件头三要素一致，运行时零依赖，整体合规状况良好；同时发现 9 个未声明文件（多为品牌图像资源）、2 处表达式误报及版权检测盲区，均已定位并给出对策。充分性说明：扫描覆盖率 100%，规则库为 SPDX 3.27，并对 12 个代表性文件做了人工抽样复核（全部一致），结论可信。

评价表格：

考核标准	得分
（1）报告格式规范、语言通顺（10%）；	
（2）质量标准分析合理（10%）；	
（3）测试方法分析全面、合理（20%）；	
（4）测试风险分析全面、合理（20%）；	
（5）测试总体测试策略全面、合理（30%）	
（6）测试充分性判断标准合理（10%）	